

# Weekly Report - W06

## 1. Thông tin chung

- ID Nhóm: **06**
- Tên nhóm: **KDBK**
- Tên project: **T09 - Security Testing (DAST / SAST)**
- Thời gian làm: 2026-07-12 - 2026-07-18

## 2. Nhiệm vụ đã hoàn thành tuần này

### 2.1. Bảng nhiệm vụ

| Nhiệm vụ                                                                                                                                                                                 | Họ tên                           |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------|
| Hoàn thiện Track Semgrep AI Triage: cấu hình OpenRouter với model Gemini, sửa script để xử lý toàn bộ findings trong JSON, bổ sung pipeline/output và kiểm thử lại luồng offline triage. | Lê Mai Hoài Bảo                  |
| Sắp xếp lại cấu trúc Track Semgrep: tài liệu để trongdocs/semgrep/, script/pipeline/runtime để trong src/semgrep/, đồng thời cập nhật hướng dẫn chạy từ root project.                    | Lê Mai Hoài Bảo                  |
| Cài đặt và chạy cơ bản Track ZAP trên môi trường local để nắm luồng scan ban đầu của công cụ.                                                                                            | Lê Mai Hoài Bảo, Lâm Hữu Khánh   |
| Rà soát bộ evidence Track ZAP, đối chiếu các tùy chọn CLI và bổ sung hướng dẫn chạy lại basic scan từ root project.                                                                      | Lâm Hữu Khánh                    |
| Cài đặt và chạy cơ bản Track Semgrep trên môi trường local để nắm luồng scan ban đầu của công cụ.                                                                                        | Lê Trung Kiên, Mai Thị Kim Duyên |
| Cấu hình authenticated scan cho ZAP với luồng đăng nhập EShop,auth-role, forced-user, AJAX Spider và inject JWT qua ZAP Replacer.                                                        | Mai Thị Kim Duyên                |
| Tùy biến output report ZAP theo path/tên file người dùng chọn, hỗ trợhtml hoặc json, đồng thời thêm scan mode basic và owasp-top10-2025.                                                 | Lê Trung Kiên                    |

### 2.2. Minh chứng

#### 2.2.1. Phân công trên Jira

- **Track Semgrep: Hoàn thiện AI Triage, pipeline và cấu trúc thư mục**
  - Mô tả: Hoàn thiện cấu hình OpenRouter với model Gemini, sửa script để xử lý toàn bộ findings, chuẩn hóa output/pipeline và cập nhật hướng dẫn chạy từ root project.
  - Thành viên: Lê Mai Hoài Bảo
  - Evidence có thể kiểm tra trong repository: evidence/semgrep/.env.example, evidence/semgrep/semgrep\_ai\_triage.py,

`evidence/semgrep/test_semgrep_ai_triage.py`,  
`evidence/semgrep/run_semgrep_pipeline.sh`,  
`evidence/semgrep/requirements.txt`, `evidence/semgrep/exploit.js`,  
`evidence/semgrep/README.md`.

- **Track ZAP: Cấu hình authenticated scan**
  - Mô tả: Thiết lập luồng đăng nhập EShop cho ZAP, gồm context, user, forced user, AJAX Spider và inject JWT qua ZAP Replacer để phục vụ scan có xác thực.
  - Thành viên: Mai Thị Kim Duyên
- **Track ZAP: Tùy biến output và scan mode**
  - Mô tả: Bổ sung lựa chọn path/tên file output, hỗ trợ report `html/json` và thêm lựa chọn scan mode `basic` hoặc `owasp-top10-2025`.
  - Thành viên: Lê Trung Kiên
- **Track cơ bản chéo giữa hai nhóm thành viên**
  - Mô tả: Lê Mai Hoài Bảo và Lâm Hữu Khánh cài đặt, chạy cơ bản ZAP; Lê Trung Kiên và Mai Thị Kim Duyên cài đặt, chạy cơ bản Semgrep để nắm luồng công cụ còn lại.
  - Thành viên: Lê Mai Hoài Bảo, Lâm Hữu Khánh, Lê Trung Kiên, Mai Thị Kim Duyên
- **Track ZAP: Rà soát evidence và hướng dẫn tái hiện basic scan**
  - Mô tả: Đối chiếu `scan_zap.py`, `zap_runtime.py` và `README.md` trong bộ evidence; kiểm tra các tham số chính và chuẩn hóa hướng dẫn chạy lại basic scan từ root project.
  - Thành viên: Lâm Hữu Khánh
  - Evidence có thể kiểm tra trong repository: `evidence/zap/scan_zap.py`, `evidence/zap/zap_runtime.py`, `evidence/zap/README.md`.

### 2.2.2. Các file/script liên quan

- `evidence/semgrep/.env.example`: bản sao cấu hình mẫu cho OpenRouter dùng model Gemini.
- `evidence/semgrep/semgrep_ai_triage.py`: bản sao script đọc kết quả Semgrep JSON và gửi từng finding sang AI để triage.
- `evidence/semgrep/test_semgrep_ai_triage.py`: bản sao unit test cho cấu hình OpenRouter và luồng xử lý findings.
- `evidence/semgrep/run_semgrep_pipeline.sh`: bản sao pipeline chạy Semgrep scan và AI triage từ root project.
- `evidence/semgrep/requirements.txt`: bản sao dependency Python cho Track Semgrep.
- `evidence/semgrep/exploit.js`: bản sao PoC minh họa khai thác hardcoded JWT secret.
- `evidence/semgrep/README.md`: bản sao hướng dẫn chạy Semgrep từ root, trở về script trong `src/semgrep/`.
- `docs/semgrep/scan.md`: cập nhật hướng dẫn dùng script trong `src/semgrep/` thay vì đặt code trong docs.
- `evidence/zap/scan_zap.py`: bản sao script CLI ZAP dùng để chọn scan mode, auth mode và định dạng report.
- `evidence/zap/zap_runtime.py`: bản sao helper runtime cho đăng nhập EShop, lấy JWT và cấu hình authenticated scan.
- `evidence/zap/README.md`: hướng dẫn chạy ZAP từ root, mô tả `basic/owasp-top10-2025`, output `html/json` và các cờ auth.

## 3. Khai báo sử dụng AI

### 3.1. Lê Trung Kiên

- Công cụ: Codex, model GPT-5.4 và GPT-5.5.
- Prompt đã sử dụng:
  - Yêu cầu AI thêm cờ để ZAP chạy theo **basic** hoặc **owasp-top10-2025**, nhưng vẫn giữ nguyên nguyên tắc ZAP scan toàn bộ và chỉ lọc active policy theo tag/rule tương ứng khi cần.
  - Yêu cầu AI thêm tùy chọn cho người dùng tự chọn path và tên file output, phục vụ tách report cho frontend user, frontend admin hoặc backend.
  - Yêu cầu AI đổi output report từ chỉ HTML sang cho phép xuất JSON để pipeline sau này có thể đọc bằng AI và đối chiếu với PoC từ Semgrep.
  - Yêu cầu AI cập nhật **README** trong **src/zap** để hướng dẫn cách chạy từ root project, không dùng lệnh phụ thuộc môi trường cá nhân.
- Mục đích sử dụng: Tăng tốc phần custom output của Track ZAP, chuẩn hóa CLI để tách report theo từng target và bổ sung report JSON cho pipeline xác minh bảo mật.
- Nội dung AI tạo ra:
  - Bản nháp mở rộng parser cho **--scan-mode**, **--report-format** và **--output-file**.
  - Gợi ý dùng ZAP Report Generation add-on với template official cho report HTML/JSON.
  - Bản nháp nội dung hướng dẫn chạy ZAP và ví dụ command cho backend/frontend.
- Nội dung tự thực hiện/kiểm chứng:
  - Đọc lại mã nguồn **scan\_zap.py** và chỉnh sửa để chỉ giữ các format thật sự dùng trong pipeline là **html** và **json**.
  - Đối chiếu với tài liệu official của ZAP để sửa lại tên template report, cách hiểu về OWASP tagging và hành vi của scan mode **basic**.
  - Tự chạy unit test/parser test và kiểm tra lại tài liệu trong **evidence/zap/README.md**.
- Tài liệu official đã đối chiếu:
  - <https://www.zaproxy.org/docs/desktop/addons/report-generation/>
  - <https://www.zaproxy.org/docs/desktop/start/features/scanners/>
  - <https://www.zaproxy.org/docs/api/>

### 3.2. Mai Thị Kim Duyên

- Công cụ: Google Gemini, model Gemini 3.1 Pro.
- Prompt đã sử dụng:
  - Yêu cầu AI sinh mã cấu hình authenticated scan cho ZAP trên EShop, bao gồm đăng nhập lấy JWT, cấu hình context, user, forced-user và gán **Authorization: Bearer ...** khi scan.
  - Yêu cầu AI gợi ý cách dùng AJAX Spider cho frontend SPA và cách giới hạn scope chỉ trong các URL local của EShop.
  - Yêu cầu AI hỗ trợ viết lại comment tiếng Việt để giải thích từng bước auth/runtime trong **zap\_runtime.py**.
  - Yêu cầu AI giải thích vì sao login qua ZAP có thể trả **401** hoặc **403**, sau đó đối chiếu lại với tài khoản test và cơ chế proxy của ZAP.
- Mục đích sử dụng: Tăng tốc phần cấu hình auth cho Track ZAP để quét được luồng user/admin của EShop và ghi lại request đã xác thực trong ZAP.
- Nội dung AI tạo ra:
  - Bản nháp logic đăng nhập EShop qua proxy ZAP và trích xuất JWT từ response login.
  - Bản nháp helper tạo context, tạo user, bật Forced User Mode và thêm Replacer rule cho header **Authorization**.

- Gợi ý sử dụng AJAX Spider cho frontend sau khi đã có phiên xác thực.
- Nội dung tự thực hiện/kiểm chứng:
  - Đọc lại `zap_runtime.py`, sửa credential mặc định và hoàn thiện logic validate chỉ cho phép scan local EShop.
  - Đối chiếu với tài liệu official của ZAP để sửa lại cách cấu hình authentication/user/replacer và cách dùng AJAX Spider.
  - Tự kiểm tra luồng lỗi 401/403 để phân biệt lỗi credential, lỗi proxy và lỗi backend từ EShop.
- Tài liệu official đã đối chiếu:
  - <https://www.zaproxy.org/docs/desktop/start/features/authmethods/>
  - <https://www.zaproxy.org/docs/desktop/start/features/users/>
  - <https://www.zaproxy.org/docs/desktop/addons/replacer/>
  - <https://www.zaproxy.org/docs/desktop/addons/ajax-spider/>

### 3.3. Lâm Hữu Khánh

- Công cụ: Codex (GPT-5).
- Prompt đã sử dụng:
  - Yêu cầu AI hướng dẫn soạn thảo tài liệu hướng dẫn (README.md) chạy basic scan bằng ZAP cho dự án EShop từ thư mục gốc của project (root project).
  - Yêu cầu AI làm rõ ý nghĩa của các cờ dòng lệnh (CLI flags) trong script `scan_zap.py` như `--target`, `--scan-mode`, `--report-format`, `--output-file`.
  - Yêu cầu AI cung cấp ví dụ cụ thể chạy lệnh xuất báo cáo dưới dạng HTML và JSON.
- Mục đích sử dụng: Soạn thảo hướng dẫn sử dụng CLI cho Track ZAP, chuẩn hóa cách chạy basic scan từ thư mục gốc và đồng nhất các tham số dòng lệnh trong tài liệu hướng dẫn chạy.
- Nội dung AI tạo ra:
  - Dự thảo cấu trúc mục "Chạy scan" và các ví dụ dòng lệnh (CLI commands) chạy từ root project.
  - Giải thích các tham số chính gồm `--scan-mode`, `--report-format`, `--output-file`.
- Nội dung tự thực hiện/kiểm chứng:
  - Đối chiếu toàn bộ tham số dòng lệnh AI gợi ý với mã nguồn thực tế của `scan_zap.py` để đảm bảo cờ CLI chính xác.
  - Chỉnh sửa đường dẫn tệp (paths) trong các câu lệnh ví dụ để khớp hoàn toàn với cấu trúc thư mục của repository (`evidence/zap/` và `src/zap/`).
  - Chạy thử nghiệm lệnh basic scan trực tiếp trên môi trường local từ root project và kiểm tra kết quả tệp báo cáo đầu ra.
- Tài liệu official đã đối chiếu:
  - <https://www.zaproxy.org/docs/desktop/cmdline/>
  - <https://www.zaproxy.org/docs/desktop/addons/report-generation/>

### 3.4. Lê Mai Hoài Bảo

- Công cụ: Codex/ChatGPT, OpenRouter, model Gemini qua OpenRouter (`google/gemini-2.5-flash-lite`).
- Prompt đã sử dụng:
  - Yêu cầu AI đọc tài liệu Semgrep trong repo và hướng dẫn cách chạy Semgrep từ bước cài đặt, scan đến AI triage.

- Yêu cầu AI sửa cấu hình `.env.example` để dùng OpenRouter với model Gemini thay vì dùng trực tiếp `GEMINI_API_KEY`.
- Yêu cầu AI sửa script để đọc `OPENROUTER_API_KEY/OPENROUTER_BASE_URL`.
- Yêu cầu AI giải thích lỗi `externally-managed-environment` khi cài package Python và hướng dẫn chuyển sang virtual environment.
- Yêu cầu AI giải thích lỗi OpenRouter `402` và đề xuất model/token phù hợp hơn.
- Yêu cầu AI sửa script để chạy tất cả findings theo số lượng lỗi trong JSON, không hardcode một lỗi.
- Yêu cầu AI sắp xếp lại repo: tài liệu ở `docs/semgrep/`, script/pipeline/runtime ở `src/semgrep/`, đồng thời viết hướng dẫn chạy từ root.
- Mục đích sử dụng: Hỗ trợ hoàn thiện workflow Semgrep AI Triage cho dự án EShop, chuẩn hóa cấu hình OpenRouter, sửa lỗi runtime, tự động hóa xử lý nhiều findings và làm rõ cấu trúc tài liệu/script trong repo.
- Nội dung AI tạo ra:
  - Đề xuất cấu hình `.env.example` dùng OpenRouter với model Gemini.
  - Bản sửa logic đọc API key/base URL từ `OPENROUTER_API_KEY` và `OPENROUTER_BASE_URL`.
  - Bản sửa script để lập qua toàn bộ findings trong `results` thay vì chỉ xử lý `findings[0]`.
  - Pipeline `run_semgrep_pipeline.sh` để chạy scan và AI triage từ root.
  - Hướng dẫn chạy trong `docs/semgrep/README.md`.
  - Unit test kiểm tra cấu hình OpenRouter và luồng xử lý findings.
- Nội dung tự thực hiện/kiểm chứng:
  - Kiểm tra lại cấu trúc thư mục để đảm bảo tài liệu nằm trong `docs/semgrep/`, code/script nằm trong `src/semgrep/`.
  - Tự chạy lệnh cài đặt trong `.venv`, scan Semgrep và chạy script triage.
  - Đối chiếu log Semgrep cho thấy có 12 findings và kiểm tra script xử lý đủ 12 findings trong chế độ offline.
  - Kiểm tra lỗi OpenRouter `402` không phải lỗi code mà do credit/token limit, sau đó đổi model sang bản nhẹ hơn.
  - Chạy unit test, kiểm tra cú pháp shell script và kiểm tra diff không có lỗi whitespace.

4. Task tuần sau

| Id | Task name                                                                               | Member            |
|----|-----------------------------------------------------------------------------------------|-------------------|
| 1  | Chuẩn bị slide và user guide cho OWASP Top 10 mục 1 và 2, kèm phần giới thiệu ngắn.     | Lê Trung Kiên     |
| 2  | Chuẩn bị slide và user guide cho OWASP Top 10 mục 3, 4 và 5, kèm phần giới thiệu ngắn.  | Mai Thị Kim Duyên |
| 3  | Chuẩn bị slide và user guide cho OWASP Top 10 mục 6 và 7, kèm phần giới thiệu ngắn.     | Lê Mai Hoài Bảo   |
| 4  | Chuẩn bị slide và user guide cho OWASP Top 10 mục 8, 9 và 10, kèm phần giới thiệu ngắn. | Lâm Hữu Khánh     |

| <b>Id</b> | <b>Task name</b>                                                                                                 | <b>Member</b>                    |
|-----------|------------------------------------------------------------------------------------------------------------------|----------------------------------|
| 5         | Viết slide và user guide giới thiệu SAST, Semgrep, hướng dẫn cài đặt/setup Semgrep.                              | Lê Mai Hoài Bảo                  |
| 6         | Viết slide và user guide hướng dẫn chạy basic scan và cách chạy Semgrep trong pipeline.                          | Lâm Hữu Khánh                    |
| 7         | Viết slide và user guide giới thiệu DAST, OWASP ZAP, hướng dẫn cài đặt/setup ZAP và cách chạy basic scan qua UI. | Lê Trung Kiên                    |
| 8         | Viết slide và user guide giới thiệu script ZAP của nhóm, gồm cách dùng các flag chính và ý nghĩa output.         | Mai Thị Kim Duyên                |
| 9         | Tạo test case để xác nhận output scan từ ZAP khớp với PoC do AI triage bên Semgrep sinh ra.                      | Lê Trung Kiên                    |
| 10        | Lên outline cho phần thuyết trình của nhóm.                                                                      | Lê Trung Kiên                    |
| 11        | Phối hợp quay video demo workflow.                                                                               | Mai Thị Kim Duyên, Lâm Hữu Khánh |
| 12        | Thực hiện AI audit và rà soát lại nội dung kỹ thuật trước khi nhóm chốt tài liệu.                                | Lê Mai Hoài Bảo                  |

## 5. Vấn đề phát sinh

- Môi trường Python global bị chặn cài package do cơ chế **externally-managed-environment**, đã xử lý bằng **.venv**.
- OpenRouter trả lỗi **402** do credit/token limit, cần dùng model nhẹ hơn hoặc bổ sung credit nếu muốn chạy toàn bộ findings bằng AI thật.
- Cần giữ rõ ranh giới repo: tài liệu trong **docs/**, script và pipeline trong **src/**.
- Luồng authenticated scan của ZAP còn phụ thuộc độ ổn định của tài khoản test EShop; khi backend trả **401** hoặc **403** cần kiểm tra lại credential, trạng thái account và request đi qua proxy ZAP.